

2017-03-25 TRAFFIC ANALYSIS EXERCISE - ANSWERS

WRITEUP:

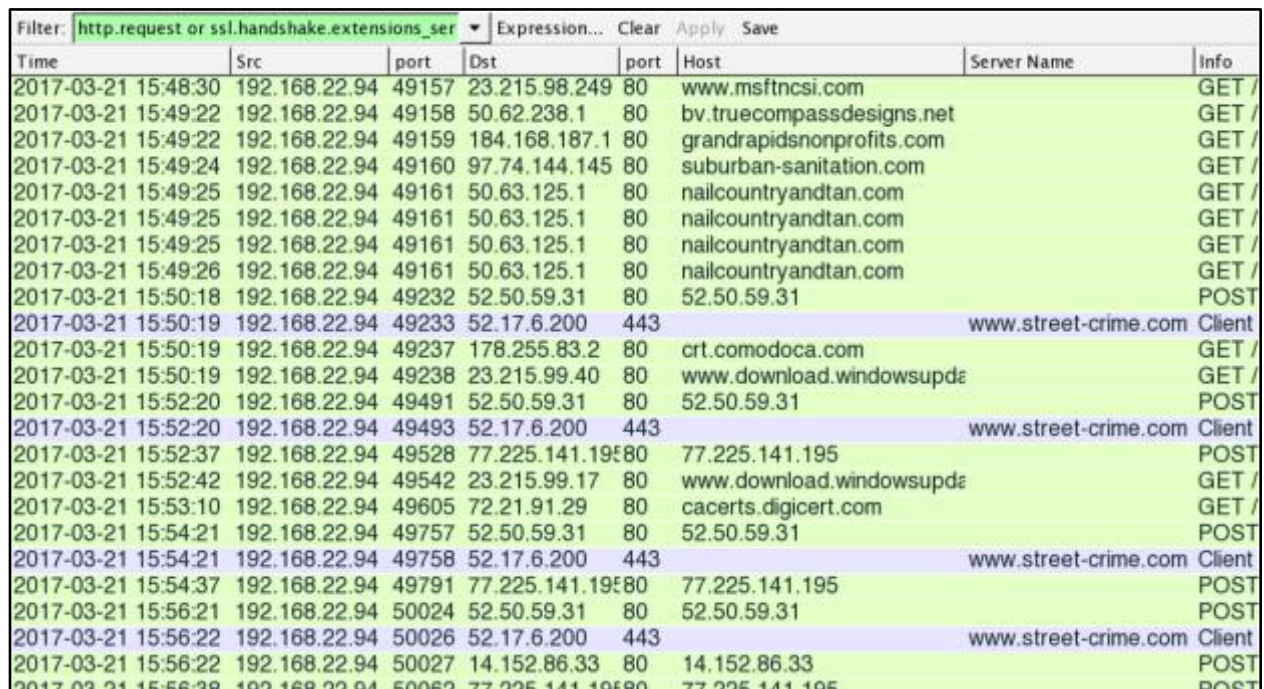
On Tuesday 2017-03-21, a Windows host at 192.168.22.94 was infected with Kovter malware, possibly from malicious spam (malspam) attachment. The infected host name was Pollerman-PC, and its MAC address was 00:1e:c9:c3:3a:1b.

DETAILS:

Wireshark is my tool of choice to examine this type of traffic. As always, I recommend you set up Wireshark in accordance with the following guides I've posted:

- <http://www.malware-traffic-analysis.net/tutorials/wireshark/index.html>

As always, the first thing I do when I look at a pcap is filter on **http.request**. For these exercises, that will show you a) the IP address of the infected host and b) the general time for the activity. In some cases, I'll filter on **http.request or ssl.handshake.extensions_server_name** which may give a better idea.



Time	Src	port	Dst	port	Host	Server Name	Info
2017-03-21 15:48:30	192.168.22.94	49157	23.215.98.249	80	www.msftncsi.com		GET /
2017-03-21 15:49:22	192.168.22.94	49158	50.62.238.1	80	bv.truecompassdesigns.net		GET /
2017-03-21 15:49:22	192.168.22.94	49159	184.168.187.1	80	grandrapidsnonprofits.com		GET /
2017-03-21 15:49:24	192.168.22.94	49160	97.74.144.145	80	suburban-sanitation.com		GET /
2017-03-21 15:49:25	192.168.22.94	49161	50.63.125.1	80	nailcountryandtan.com		GET /
2017-03-21 15:49:25	192.168.22.94	49161	50.63.125.1	80	nailcountryandtan.com		GET /
2017-03-21 15:49:25	192.168.22.94	49161	50.63.125.1	80	nailcountryandtan.com		GET /
2017-03-21 15:49:26	192.168.22.94	49161	50.63.125.1	80	nailcountryandtan.com		GET /
2017-03-21 15:50:18	192.168.22.94	49232	52.50.59.31	80	52.50.59.31		POST
2017-03-21 15:50:19	192.168.22.94	49233	52.17.6.200	443		www.street-crime.com	Client
2017-03-21 15:50:19	192.168.22.94	49237	178.255.83.2	80	crt.comodoca.com		GET /
2017-03-21 15:50:19	192.168.22.94	49238	23.215.99.40	80	www.download.windowupdate.com		GET /
2017-03-21 15:52:20	192.168.22.94	49491	52.50.59.31	80	52.50.59.31		POST
2017-03-21 15:52:20	192.168.22.94	49493	52.17.6.200	443		www.street-crime.com	Client
2017-03-21 15:52:37	192.168.22.94	49528	77.225.141.195	80	77.225.141.195		POST
2017-03-21 15:52:42	192.168.22.94	49542	23.215.99.17	80	www.download.windowupdate.com		GET /
2017-03-21 15:53:10	192.168.22.94	49605	72.21.91.29	80	cacerts.digicert.com		GET /
2017-03-21 15:54:21	192.168.22.94	49757	52.50.59.31	80	52.50.59.31		POST
2017-03-21 15:54:21	192.168.22.94	49758	52.17.6.200	443		www.street-crime.com	Client
2017-03-21 15:54:37	192.168.22.94	49791	77.225.141.195	80	77.225.141.195		POST
2017-03-21 15:56:21	192.168.22.94	50024	52.50.59.31	80	52.50.59.31		POST
2017-03-21 15:56:22	192.168.22.94	50026	52.17.6.200	443		www.street-crime.com	Client
2017-03-21 15:56:22	192.168.22.94	50027	14.152.86.33	80	14.152.86.33		POST
2017-03-21 15:56:28	192.168.22.94	50062	77.225.141.195	80	77.225.141.195		POST

Shown above: Filtering in Wireshark.

The pcap starts at 2017-03-21 at 15:48 UTC, and the traffic starts at 15:49 UTC. You can see all the source IP addresses are 192.168.22.94.

To get the host name, and MAC address, you can examine the NetBIOS name service (NBNS) traffic, or you can look at the DHCP traffic as shown in the images below.

2017-03-25 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Time	Src	port	Dst	port	Info
2017-03-21 15:48:24	192.168.22.94	50250	224.0.0.252	5355	Standard query 0x1ada ANY pollerman-PC
2017-03-21 15:48:24	192.168.22.94		224.0.0.22		Membership Report / Join group 224.0.0.22
2017-03-21 15:48:24	192.168.22.94	137	192.168.22.255	137	Registration NB POLLERMAN-PC<00>
2017-03-21 15:48:24	192.168.22.94	137	192.168.22.255	137	Registration NB WORKGROUP<00>
2017-03-21 15:48:24	192.168.22.94	137	192.168.22.255	137	Registration NB POLLERMAN-PC<00>
Frame 10: 110 bytes on wire (880 bits), 110 bytes captured (880 bits)					
Ethernet II, Src: Dell_c3:3a:1b (00:1e:c9:c3:3a:1b), Dst: Broadcast (ff:ff:ff:ff:ff:ff)					
Internet Protocol Version 4, Src: 192.168.22.94, Dst: 192.168.22.255 (192.168.22.255)					
User Datagram Protocol, Src Port: 137 (137), Dst Port: 137 (137)					
NetBIOS Name Service					
Transaction ID: 0xb58e					
Flags: 0x2910 (Registration)					
Questions: 1					
Answer RRs: 0					
Authority RRs: 0					
Additional RRs: 1					
Queries					
Additional records					
POLLERMAN-PC<00>: type NB, class IN					
Name: POLLERMAN-PC<00> (Workstation/Redirector)					
Type: NB					
Class: IN					
Time to live: 3 days, 11 hours, 20 minutes					
Data length: 6					
Name flags: 0x0000 (B-node, unique)					
Addr: 192.168.22.94					

Shown above: Examining one of the NBNS packets in Wireshark.

Filter:	udp.port eq 67	Expression...	Clear	Apply	Save
Time	Src	port	Dst	port	Info
2017-03-21 15:48:19	0.0.0.0	68	255.255.255.255	67	DHCP Request - T
2017-03-21 15:48:19	192.168.22.1	67	192.168.22.94	68	DHCP ACK - Tr
2017-03-21 15:48:24	0.0.0.0	68	255.255.255.255	67	DHCP Request - T
2017-03-21 15:48:24	192.168.22.1	67	192.168.22.94	68	DHCP ACK - Tr
2017-03-21 15:48:27	192.168.22.94	68	255.255.255.255	67	DHCP Inform - Tr
2017-03-21 15:48:27	192.168.22.1	67	192.168.22.94	68	DHCP ACK - Tr
2017-03-21 16:18:24	192.168.22.94	68	192.168.22.1	67	DHCP Request - T
2017-03-21 16:18:24	192.168.22.1	67	192.168.22.94	68	DHCP ACK - Tr
Client IP address: 192.168.22.94 (192.168.22.94)					
Your (client) IP address: 0.0.0.0 (0.0.0.0)					
Next server IP address: 0.0.0.0 (0.0.0.0)					
Relay agent IP address: 0.0.0.0 (0.0.0.0)					
Client MAC address: Dell_c3:3a:1b (00:1e:c9:c3:3a:1b)					
Client hardware address padding: 00000000000000000000					
Server host name not given					
Boot file name not given					
Magic cookie: DHCP					
Option: (53) DHCP Message Type (Request)					
Option: (61) Client identifier					
Option: (12) Host Name					
Length: 12					
Host Name: pollerman-PC					
Option: (81) Client Fully Qualified Domain Name					

Shown above: Examining the DHCP traffic in Wireshark.

2017-03-25 TRAFFIC ANALYSIS EXERCISE - ANSWERS

So what happened here? Let's look at the domains again.

Host	Server Name	Info
www.msftncsi.com		GET /ncsi.txt HTTP/1.1
bv.truecompassdesigns.net		GET /counter/?0000001MKqMAdoTwsD8bMb
grandrapidsnonprofits.com		GET /counter/?0000001MKqMAdoTwsD8bMb
suburban-sanitation.com		GET /counter/?0000001MKqMAdoTwsD8bMb
nailcountryandtan.com		GET /counter/?0000001MKqMAdoTwsD8bMb
nailcountryandtan.com		GET /counter/?0000001MKqMAdoTwsD8bMb
nailcountryandtan.com		GET /counter/?0000001MKqMAdoTwsD8bMb
nailcountryandtan.com		GET /counter/?0000001MKqMAdoTwsD8bMb
52.50.59.31		POST / HTTP/1.1 (application/x-www-form-url
	www.street-crime.com	Client Hello
crt.comodoca.com		GET /COMODORSAAddTrustCA.crt HTTP/1.
www.download.windowsupd		GET /msdownload/update/v3/static/trustedr/er
52.50.59.31		POST / HTTP/1.1 (application/x-www-form-url
	www.street-crime.com	Client Hello
77.225.141.195		POST / HTTP/1.1 (application/x-www-form-url
www.download.windowsupd		GET /msdownload/update/v3/static/trustedr/er
cacerts.digicert.com		GET /DigiCertSHA2SecureServerCA.crt HTTP
52.50.59.31		POST / HTTP/1.1 (application/x-www-form-url
	www.street-crime.com	Client Hello
77.225.141.195		POST / HTTP/1.1 (application/x-www-form-url
52.50.59.31		POST / HTTP/1.1 (application/x-www-form-url
	www.street-crime.com	Client Hello
14.152.86.33		POST / HTTP/1.1 (application/x-www-form-url
77.225.141.195		POST / HTTP/1.1 (application/x-www-form-url

Shown above: Looking at the HTTP and HTTPS traffic in Wireshark..

The following IP addresses and domains are found in the pcap:

- 50.62.238.1 port 80 - ***bv.truecompassdesigns.net***
- 184.168.187.1 port 80 - ***grandrapidsnonprofits.com***
- 97.74.144.145 port 80 - ***suburban-sanitation.com***
- 50.63.125.1 port 80 - ***nailcountryandtan.com***
- 52.50.59.31 port 80 - ***52.50.59.31***
- 52.17.6.200 port 443 - ***www.street-crime.com*** (HTTPS/SSL/TLS traffic)
- 77.225.141.195 port 80 - ***77.225.141.195***
- 14.152.86.33 port 80 - ***14.152.86.33***
- 60.169.77.199 port 80 - ***60.169.77.199***

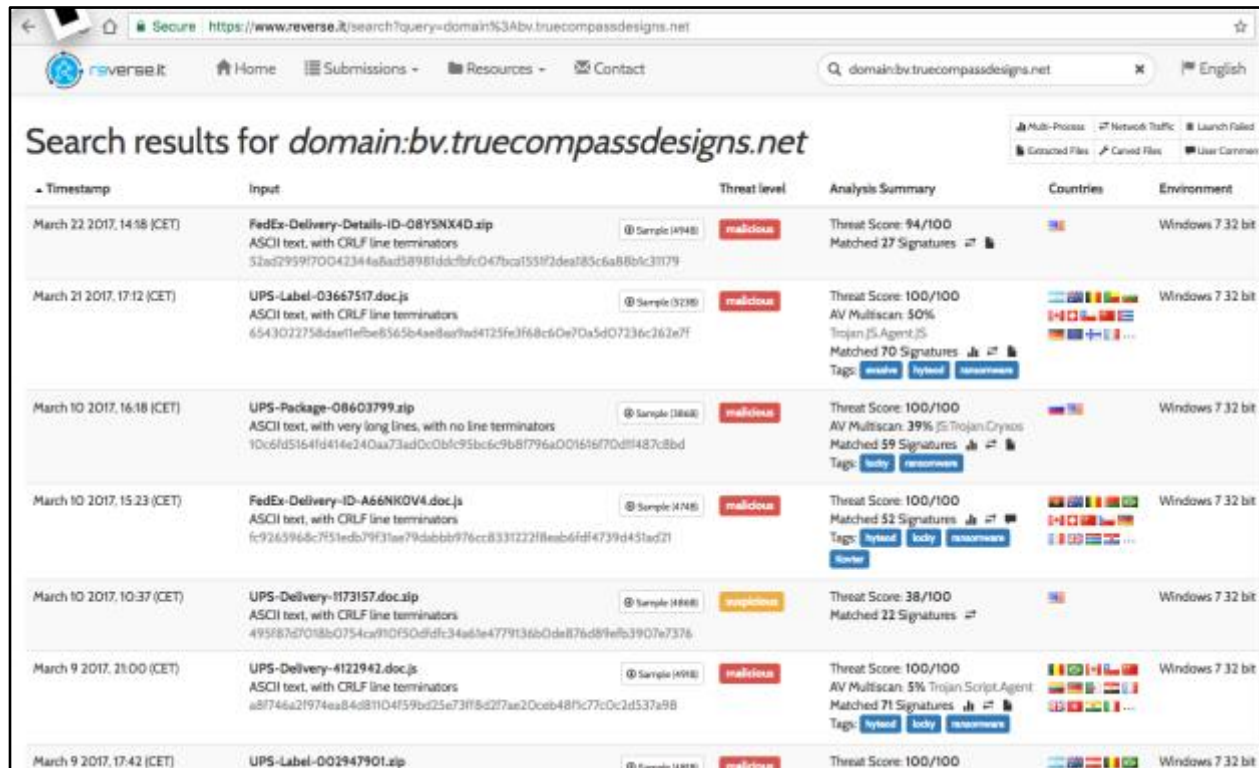
Here's a trick to see if there's any malware involved with those domains. First, register for an account at [reverse.it](https://reverseit.io/). The accounts only require a name, password, and valid email address. Both [reverse.it](https://reverseit.io/) and hybrid-analysis.com are the same. If you register for one, you have an account on both.

Once you've registered and signed in, search the domains. Forget www.msftncsi.com (that's a Microsoft domain). Start with the first one, ***bv.truecompassdesigns.net***.

2017-03-25 TRAFFIC ANALYSIS EXERCISE - ANSWERS

When searching domains on reverse.it, use the following format:

- **domain:[domain name]**



The screenshot shows the reverse.it search results for the domain `domain:bv.truecompassdesigns.net`. The results are displayed in a table with columns: Timestamp, Input, Threat level, Analysis Summary, Countries, and Environment. The table lists several files, including FedEx delivery notices and UPS package notifications, which are identified as malicious or suspicious. The threat levels range from 'malicious' to 'suspicious'.

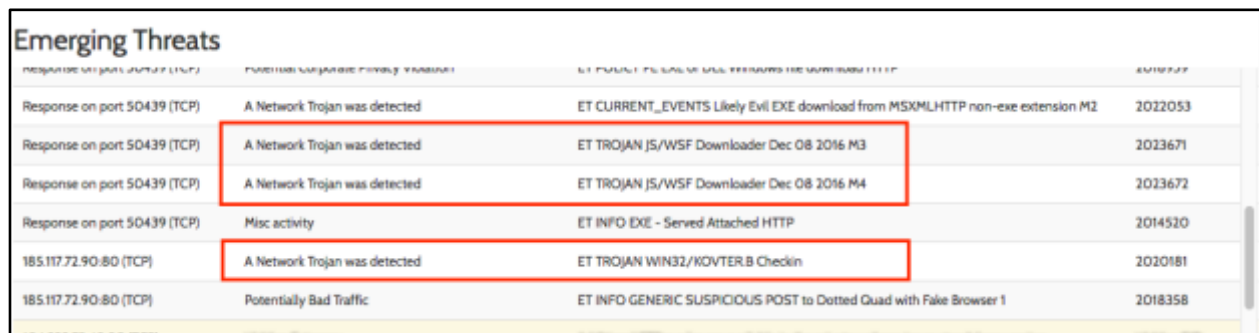
Timestamp	Input	Threat level	Analysis Summary	Countries	Environment
March 22 2017, 14:58 (CET)	FedEx-Delivery-Details-ID-08YSNX4D.zip ASCII text, with CRLF line terminators 52ad295970042344e8ad58981ddcfbfc047bca1551f2dea785c6a88b6c37079	malicious	Threat Score: 94/100 Matched 27 Signatures		Windows 7 32 bit
March 21 2017, 17:12 (CET)	UPS-Label-03667517.doc.js ASCII text, with CRLF line terminators 6543022758d8e1efbe8565b4ee8ee7ad4125fe3f68c60e70a5d07236c362e7f	malicious	Threat Score: 100/100 AV Multiscan: 50% Trojan.JS.Agent.js Matched 70 Signatures		Windows 7 32 bit
March 10 2017, 16:18 (CET)	UPS-Package-08603799.zip ASCII text, with very long lines, with no line terminators 10c6fd5164fd41e240aa73ad0c0bfc95b6c9b8f796a00165bf70d11487c8bd	malicious	Threat Score: 100/100 AV Multiscan: 39% JS.Trojan.Cryxos Matched 59 Signatures		Windows 7 32 bit
March 10 2017, 15:23 (CET)	FedEx-Delivery-ID-A66NKOV4.doc.js ASCII text, with CRLF line terminators fc926596d8c7f51ed079f31ae79dabb97f6cc8331222f8eeb6fd4739d451ad21	malicious	Threat Score: 100/100 Matched 52 Signatures		Windows 7 32 bit
March 10 2017, 10:37 (CET)	UPS-Delivery-1173157.doc.zip ASCII text, with CRLF line terminators 495f87d7018b0754ca910f50ddfc34a61e4779136b0de876d89f6b3907e7376	suspicious	Threat Score: 38/100 Matched 22 Signatures		Windows 7 32 bit
March 9 2017, 21:00 (CET)	UPS-Delivery-4122942.doc.js ASCII text, with CRLF line terminators a8f746a2f974ea84d81104f59bd25e73f1b6d277ae20ceb48f6c77c0c2d537a98	malicious	Threat Score: 100/100 AV Multiscan: 5% Trojan.Script.Agent Matched 71 Signatures		Windows 7 32 bit
March 9 2017, 17:42 (CET)	UPS-Label-002947901.zip	malicious	Threat Score: 100/100		Windows 7 32 bit

Shown above: Results of a domain search on reverse.it.

You'll find a few zip archives and .js files posing as UPS package notifications and FedEx delivery notices. This is often seen in malspam.

Since the date of our traffic is March 21st, click on the entry for the .js file submitted on March 21st. In that entry, if you scroll down to the DNS requests and HTTP traffic, you'll find domains and HTTP requests that match the ones from our exercise pcap.

Scroll down to the Emerging Threats (ET) section, and you'll see alerts for a JS Downloader Trojan. You'll also find an alert for a Kovter.B Checkin. The ET Pro alerts are shaded out, so we won't see those.



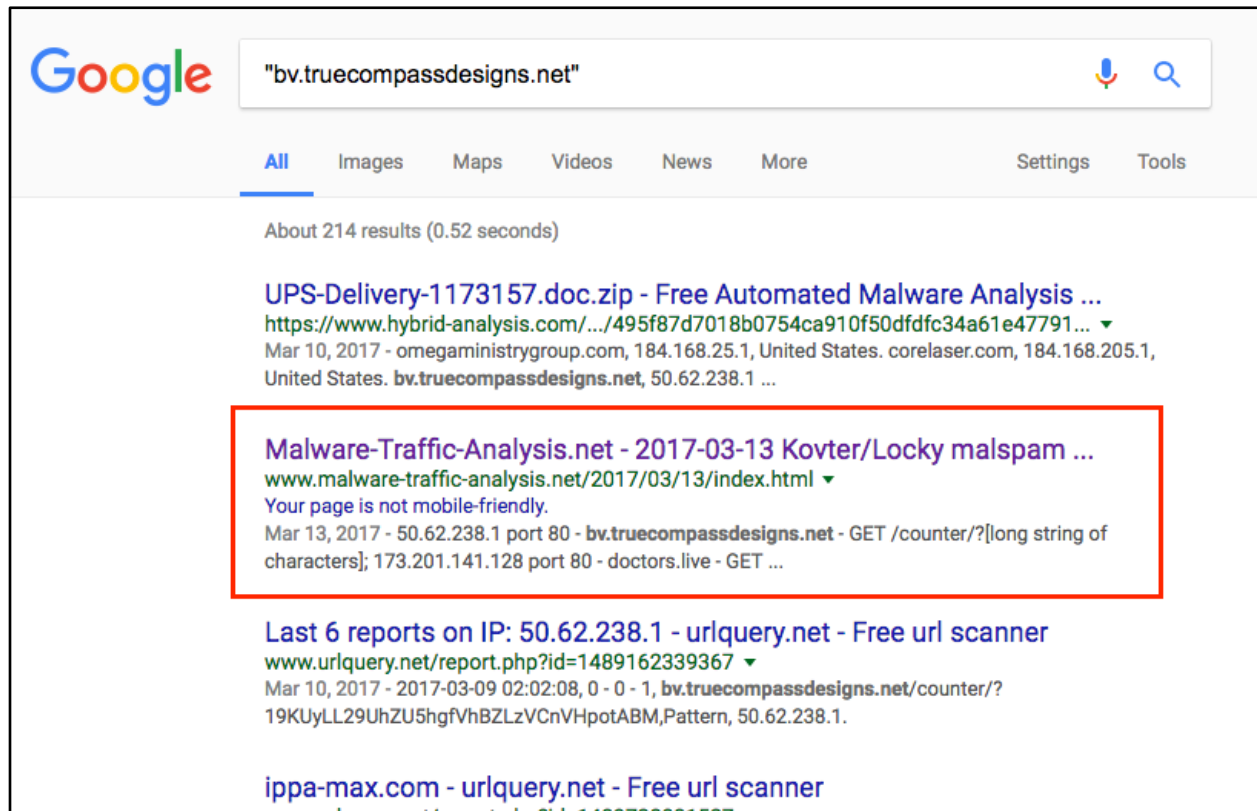
The screenshot shows the Emerging Threats (ET) section of reverse.it. It displays a table of alerts with columns: Response on port 50439 (TCP), Input, ET Alert, and Timestamp. Several alerts are highlighted with red boxes, indicating detections of a Network Trojan and a JS Downloader Trojan.

Response on port 50439 (TCP)	Input	ET Alert	Timestamp
Response on port 50439 (TCP)	A Network Trojan was detected	ET CURRENT_EVENTS Likely Evil EXE download from MSXMLHTTP non-exe extension M2	2022053
Response on port 50439 (TCP)	A Network Trojan was detected	ET TROJAN JS/WSF Downloader Dec 08 2016 M3	2023671
Response on port 50439 (TCP)	A Network Trojan was detected	ET TROJAN JS/WSF Downloader Dec 08 2016 M4	2023672
Response on port 50439 (TCP)	Misc activity	ET INFO EXE - Served Attached HTTP	2014520
185.117.72.90:80 (TCP)	A Network Trojan was detected	ET TROJAN WIN32/KOVTER.B Checkin	2020181
185.117.72.90:80 (TCP)	Potentially Bad Traffic	ET INFO GENERIC SUSPICIOUS POST to Dotted Quad with Fake Browser 1	2018358

Shown above: Emerging Threats alerts on reverse.it for the .js malware sample.

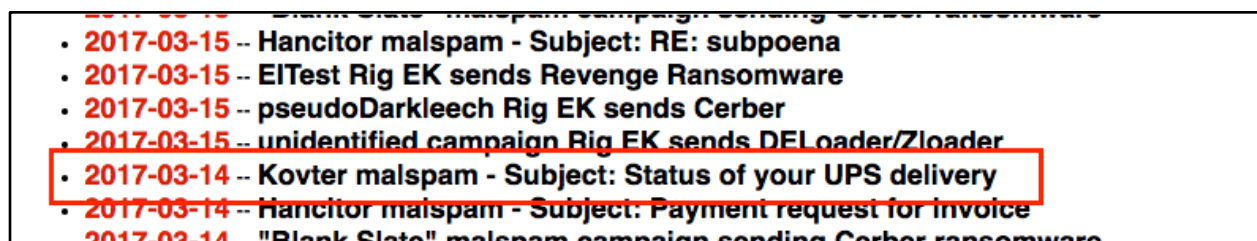
2017-03-25 TRAFFIC ANALYSIS EXERCISE - ANSWERS

So now we have an idea of what happened. Furthermore, you can search on Google for "***bv.truecompassdesigns.net***" (make sure you use quotation marks around the domain name) and you'll find an entry on malware-traffic-analysis.net for a Kovter/Locky malspam infection that's similar to our exercise pcap.



Shown above: A google search on ***bv.truecompassdesigns.net***.

The blog is at malware-traffic-analysis.net/2017/03/13/index.html where you'll find similar traffic. However, our exercise pcap doesn't have any Locky indicators. If you check my later blog posts, you'll find a Kovter infection that doesn't have Locky on 2017-03-14 at malware-traffic-analysis.net/2017/03/14/index3.html



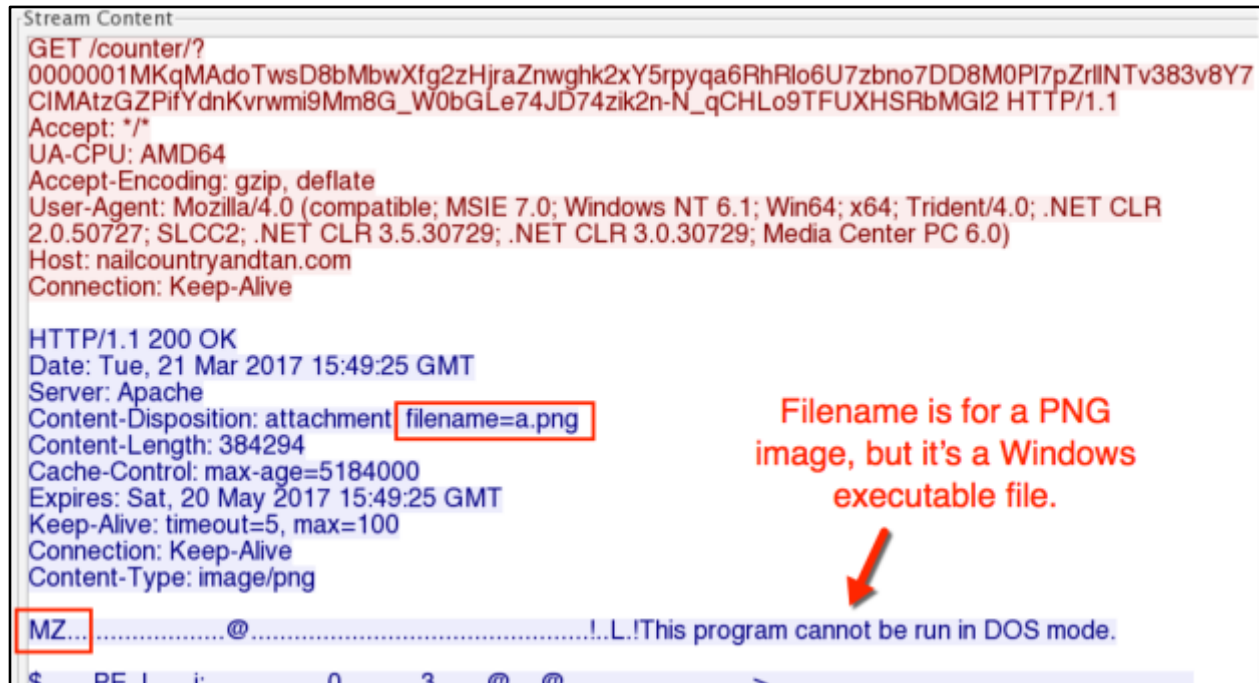
Shown above: Another blog entry with Kovter malspam.

That blot post shows Nemucod ransomware, and no alerts are seen there for it. Perhaps it didn't generate any post-infection traffic. Without more information, we can only state there was Kovter malware involved in this infection.

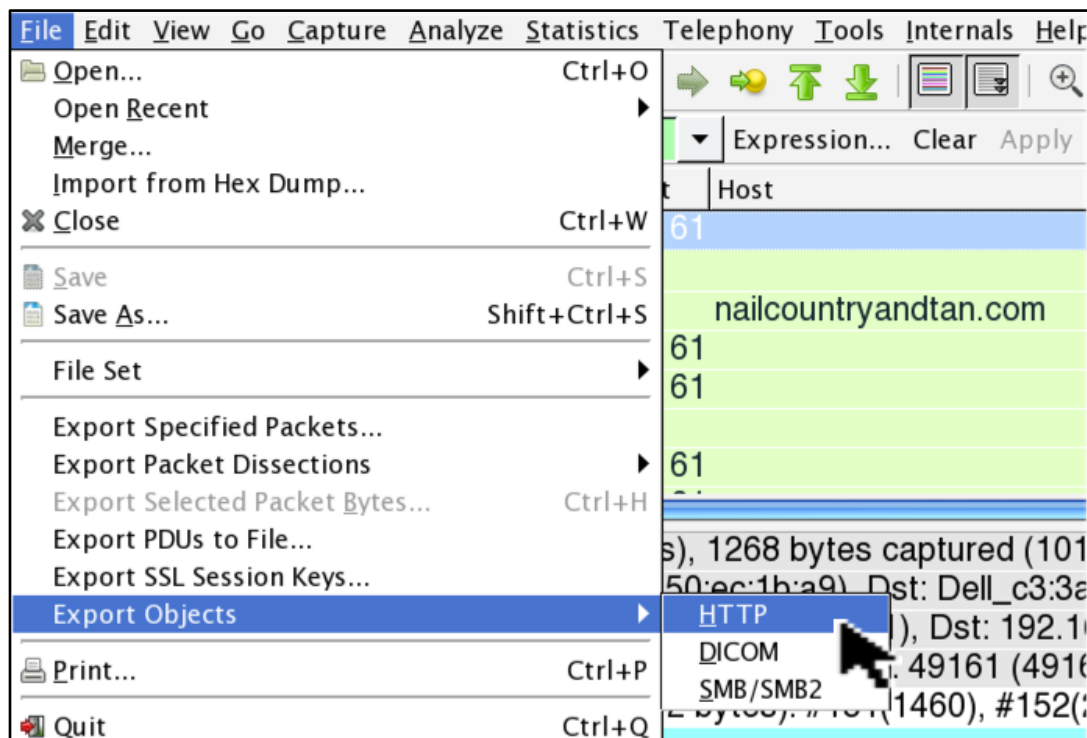
2017-03-25 TRAFFIC ANALYSIS EXERCISE - ANSWERS

FINAL WORDS

There's much more you can do with the pcap. You can export the HTTP objects and look at the files. Anything that's listed as a PNG file is really a Windows executable.



Shown above: Malware downloaded as a PNG file, but is really a Windows executable.



Shown above: Exporting HTTP objects from the pcap.

2017-03-25 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Packet num	Hostname	Content Type	Size	Filename
68	www.msftncsi.com	text/plain	14 bytes	ncsi.txt
98	bv.truecompassdesigns.net	text/html	140 bytes	?0000001MKqMAAdoT
108	grandrapidsnonprofits.com	text/html	7886 bytes	?0000001MKqMAAdoT
142	suburban-sanitation.com	text/javascript	27 kB	?0000001MKqMAAdoT
558	nailcountryandtan.com	image/png	384 kB	?0000001MKqMAAdoT
616	nailcountryandtan.com	image/png	45 kB	?0000001MKqMAAdoT
2067	nailcountryandtan.com	image/png	1417 kB	?0000001MKqMAAdoT
2071	nailcountryandtan.com	image/png	2297 bytes	?0000001MKqMAAdoT
2156	52.50.59.31	application/x-www-form-urlencoded	476 bytes	/
2158	52.50.59.31	text/html	185 bytes	/
2184	crt.comodoca.com	application/x-x509-ca-cert	1400 bytes	COMODORSAAAddTru
2196	www.download.windowsupdate.com	application/x-x509-ca-cert	1082 bytes	02FAF3E2914354686
2514	52.50.59.31	application/x-www-form-urlencoded	440 bytes	/

Shown above: Some of executables & other interesting objects from the pcap.

You can also review that entry for the .js we looked at earlier to see if the file hashes match. You can playback the pcap through [Security Onion](#), and you can conduct further analysis.

But we've answered the questions posed by the exercise, and nothing more is required. It might be time to move on. If you're a security analyst responsible for identifying malicious activity, there are plenty of suspicious events for you to review.